



23/Feb/2026

Theoretical Knowledge

1: SOC Fundamentals and Operations

A Security Operations Center (SOC) is a centralized function within an organization employing people, processes, and technology to continuously monitor and improve an organization's security posture while preventing, detecting, analyzing, and responding to cybersecurity incidents.

A. The Purpose of a SOC

The SOC operates on the principle that perimeter defenses (like firewalls and basic antivirus) will eventually be breached. Its purpose is to shift an organization from a purely reactive security posture to a proactive one.

Continuous Monitoring (24/7/365): Cyber threats do not adhere to business hours. The SOC provides total visibility across all endpoints, servers, network traffic, and cloud environments.

Proactive Threat Detection: Moving beyond signature-based detection (waiting for a known virus) to heuristic and behavioral analytics to identify anomalous activity that indicates a breach.

Incident Response (IR): When an alert is validated as a true positive, the SOC dictates the immediate steps to contain the threat (e.g., isolating an infected machine from the network), eradicate the root cause, and recover normal business operations.

Reducing Dwell Time: Dwell time is the duration a threat actor remains undetected inside the network. A primary KPI (Key Performance Indicator) of a SOC is reducing MTTD (Mean Time to Detect) and MTTR (Mean Time to Respond).

B. SOC Roles and Hierarchy

To manage the massive volume of data and alerts, a SOC is strictly structured into escalation tiers.

Tier 1: Triage Specialist (Security Analyst)

Responsibility: The first line of defense. They monitor the SIEM (Security Information and Event Management) dashboard for incoming alerts.

Tasks: Reviewing alerts to separate "True Positives" (actual threats) from "False Positives" (benign activity flagged by mistake). If an alert requires deeper investigation, they open a ticket and escalate it to Tier 2.



23/Feb/2026

Tier 2: Incident Responder

Responsibility: Deep-dive analysis on escalated tickets.

Tasks: Reviewing network traffic captures (PCAPs), analyzing endpoint logs, determining the scope of the attack, and implementing containment strategies. They advise IT teams on remediation.

Tier 3: Threat Hunter / SME (Subject Matter Expert)

Responsibility: Proactive security and advanced forensics.

Tasks: They assume the network is already compromised and actively search for hidden, persistent threats (APTs) that bypassed Tier 1 and 2 defenses. They also perform advanced malware reverse-engineering.

Security Engineer: (Crucial backend role) They do not handle alerts; instead, they build and maintain the SOC infrastructure. They integrate new log sources, tune the SIEM to reduce false positives, and write custom detection rules.

SOC Manager: Oversees operations, manages shifts, tracks metrics (MTTD/MTTR), and acts as the liaison between the technical team and executive leadership (CISO).

C. Key Functions and Workflows

The day-to-day operations rely on a specific pipeline of data and intelligence.

Log Analysis & SIEM: The lifeblood of the SOC is logs (records of digital events). Logs from firewalls, active directory, endpoints, and applications are fed into a SIEM (e.g., Splunk, Microsoft Sentinel, IBM QRadar). The SIEM aggregates, normalizes, and correlates this massive data pool to trigger alerts based on suspicious patterns.

Alert Triage & Investigation Workflow:

1. Preparation: Ingesting logs.
2. Detection: SIEM fires an alert.
3. Analysis: Analyst investigates the context (Who is the user? What is the asset? Is the behavior normal?).
4. Containment/Remediation: Stopping the threat.

Threat Intelligence Integration: SOCs ingest feeds of global threat data. This includes IOCs (Indicators of Compromise) such as malicious IP addresses, domains, and file hashes. If an internal machine communicates with an IP known to be malicious on a threat feed, an alert is generated instantly.



23/Feb/2026

Automation via SOAR: To handle alert fatigue, SOCs use SOAR (Security Orchestration, Automation, and Response) platforms like Splunk Phantom. SOAR uses "Playbooks"—automated scripts that execute standard procedures. For example, a phishing playbook might automatically extract URLs from a reported email, check them against a threat database, and delete the email from all inboxes if deemed malicious, without human intervention.

D. Industry Frameworks

SOCs do not improvise; they strictly adhere to globally recognized frameworks to ensure comprehensive security.

NIST Cybersecurity Framework (CSF): A high-level guide outlining five core pillars of a security program:

Identify: Understand your assets and risks.

Protect: Implement safeguards (firewalls, training).

Detect: Find anomalies and events (The SOC's primary domain).

Respond: Take action against a detected event.

Recover: Restore services and learn from the event.

NIST Incident Response Lifecycle (NIST SP 800-61): A strict 4-step process for handling breaches: Preparation -> Detection & Analysis -> Containment, Eradication & Recovery -> Post-Incident Activity (Lessons Learned).

MITRE ATT&CK® Framework: A massive, detailed knowledge base of adversary behavior. It maps out Tactics (what the attacker is trying to achieve, e.g., "Initial Access") and Techniques (how they achieve it, e.g., "Phishing"). SOCs use this to map their detection rules against known real-world attack strategies to find gaps in their defense.

E. SIEM vs. SOAR

These two technologies form the technological backbone of modern SOC operations. It is crucial to understand the difference between them: the SIEM is the "brain" that detects, and the SOAR is the "hands" that react.

1. SIEM (Security Information and Event Management)

A SIEM is a centralized platform that collects, stores, and analyzes log data from across the entire IT infrastructure. Its primary job is visibility and detection.

Data Aggregation: The SIEM continuously pulls log data from firewalls, routers, servers, antivirus software, and databases.



23/Feb/2026

Data Normalization: Different devices speak different "languages" (format their logs differently). The SIEM normalizes this data into a single, standardized format so it can be queried easily.

Correlation: This is the SIEM's superpower. It uses complex mathematical rules to connect seemingly unrelated events.

Example: One failed login is normal. However, if the SIEM correlates 50 failed logins on a VPN, followed by one successful login, followed immediately by a massive data download from an internal server, it will trigger a high-severity alert for potential credential theft and data exfiltration.

Alerting & Dashboards: It presents these correlated events to Tier 1 analysts via dashboards and generates alerts based on priority.

2. SOAR (Security Orchestration, Automation, and Response)

While a SIEM generates alerts, it does not fix the problem. This leads to "alert fatigue" for analysts. SOAR was created to automate the response to those alerts.

Orchestration: SOAR integrates deeply with other security tools via APIs. It allows the SIEM, firewalls, and endpoint protection tools to "talk" to each other.

Automation (Playbooks): SOAR executes predefined workflows called "Playbooks" for common threats.

Example: If the SIEM flags a phishing email, the SOAR playbook can automatically extract the suspicious URL, check it against VirusTotal (threat intelligence), and if it comes back malicious, automatically instruct the email server to delete that email from every employee's inbox—all in seconds, before an analyst even opens the ticket.

Response: By handling the repetitive, low-level alerts automatically, SOAR frees up human analysts to focus on complex threat hunting (Tier 3 work).

F. The Frameworks (NIST vs. MITRE ATT&CK)

SOC analysts do not guess how to respond to threats; they follow established methodologies.

The NIST Incident Response Lifecycle (SP 800-61)

Developed by the National Institute of Standards and Technology, this is the gold standard for how a SOC handles a confirmed security breach from start to finish.

Phase 1: Preparation: Occurs before a breach. Involves training staff, configuring the SIEM, setting up communication plans, and creating response playbooks.



23/Feb/2026

Phase 2: Detection and Analysis: The SIEM triggers an alert. Analysts investigate the scope of the breach, identify the attack vector, and confirm if it is a true positive.

Phase 3: Containment, Eradication, and Recovery: * Containment: Stopping the bleeding (e.g., unplugging an infected server).

Eradiation: Removing the threat (e.g., deleting malware, patching the vulnerability).

Recovery: Bringing systems safely back online and monitoring them closely.

Phase 4: Post-Incident Activity: The "Lessons Learned" phase. The SOC reviews what happened, how well the team responded, and updates their defenses to ensure it never happens again.

The MITRE ATT&CK® Framework

While NIST tells a SOC how to respond, MITRE ATT&CK tells the SOC what the enemy is doing. It is a globally accessible encyclopedia of cyber adversary behavior.

Tactics (The "Why"): These represent the attacker's technical goals. Examples include Initial Access (getting in), Privilege Escalation (getting admin rights), or Exfiltration (stealing data).

Techniques (The "How"): These represent how the attacker achieves those goals. Under the tactic of Initial Access, a technique might be Phishing or Exploiting Public-Facing Applications.

How the SOC uses it: SOC engineers map their SIEM detection rules against the MITRE matrix. If they realize they have 50 rules to detect "Initial Access" but zero rules to detect "Exfiltration," they know exactly where their security blind spots are and can build new rules to cover those gaps.



23/Feb/2026

2:Security Monitoring Basics

Security monitoring acts as the "eyes and ears" of the Security Operations Center. It involves the continuous collection, analysis, and interpretation of data from across the IT environment to identify potential security threats before they can cause significant damage.

A. Core Objectives of Security Monitoring

The primary goal of monitoring is to maintain a state of continuous visibility. Analysts look for specific categories of events:

- **Detecting Anomalies:** An anomaly is any behavior that deviates from a strictly defined "normal" baseline. If a user typically downloads 50MB of data a day, a sudden spike to 50GB is an anomaly. Monitoring tools use behavioral analytics to flag these deviations, which often indicate compromised accounts or malware.
- **Identifying Unauthorized Access:** This involves monitoring authentication logs for brute-force attacks, credential stuffing, or anomalous logins (e.g., a user logging in from India and the United States within a ten-minute window, known as "impossible travel").
- **Spotting Policy Violations:** Not all threats are external. Monitoring ensures internal users comply with corporate security policies. This includes detecting the use of unauthorized software ("Shadow IT"), attempts to bypass web filters, or transferring sensitive data to unapproved personal cloud storage.

B. Essential Monitoring Tools

Security monitoring relies on a stack of specialized tools to capture different layers of network activity.

- **SIEM (Security Information and Event Management):** Platforms like **Splunk** or **Elastic Security** are the central hub. They aggregate millions of log files from endpoints, servers, and firewalls, correlate the data, and provide visual dashboards and alerts for analysts to review.
- **Network Traffic Analyzers:** Tools like **Wireshark** or **Zeek** are used for deep-dive investigations. While a SIEM might tell you a suspicious connection occurred, a packet analyzer allows analysts to inspect the actual data packets (PCAPs) crossing the network to see exactly what payload or commands were transmitted.
- **Endpoint Detection and Response (EDR):** (Complementary to network tools) Agents installed directly on machines (laptops, servers) that monitor individual processes, file modifications, and registry changes.



23/Feb/2026

C. Key Performance Metrics (KPIs)

To measure the effectiveness of the monitoring rules and the SOC team, specific metrics are tracked. Understanding the difference between these alert types is crucial for tuning security tools.

- **True Positives:** An alert triggers, and it is a genuine security threat. This is the monitoring system working correctly.
- **False Positives:** An alert triggers, but the activity is benign (e.g., an administrator performing a routine network scan flagged as an attack). High false-positive rates cause "alert fatigue," wasting analysts' time.
- **False Negatives:** The worst-case scenario. A genuine attack occurs, but the system fails to generate an alert. This indicates a blind spot in the monitoring rules.
- **MTTD (Mean Time to Detect):** The average amount of time it takes the SOC to discover a security breach after it has occurred. The primary goal of tuning monitoring tools is to drive the MTTD as close to zero as possible.

D. Practical Application and Lab Methodology

To transition this theoretical knowledge into practical skills during the internship, the following training methodology will be utilized:

- **Lab Environment Setup:** Deployment of an open-source SIEM stack (such as the Elastic Stack: Elasticsearch, Logstash, Kibana) within a controlled virtual machine environment.
- **Log Analysis Practice:** Generating and ingesting sample network traffic and endpoint logs into the SIEM to practice querying data, identifying suspicious patterns, and building custom detection dashboards.
- **Simulated Attack Scenarios:** Utilizing industry-standard training datasets, such as Splunk's "**Boss of the SOC**" (**BOTS**) datasets. These datasets contain realistic, pre-recorded artifacts of Advanced Persistent Threat (APT) attack scenarios, allowing analysts to practice tracking an attacker's lateral movement through a network.



23/Feb/2026

3: Log Management Fundamentals

In a Security Operations Center, logs are the ultimate source of truth. A log is a computer-generated record of an event that happened on a network or endpoint. **Log Management** is the systematic process of handling these massive volumes of data so that they are useful for security monitoring, threat hunting, and compliance.

A. The Log Lifecycle

Managing logs at an enterprise scale requires a strict, multi-stage pipeline to ensure data is accurate, searchable, and secure.

- **1. Collection (Ingestion):** The process of gathering raw logs from diverse sources (servers, firewalls, applications). This is typically done using lightweight software agents (like Elastic Beats or Splunk Universal Forwarders) or network protocols (like Syslog) that "push" or "pull" data to a central server.
- **2. Normalization (Parsing):** Raw logs come in hundreds of different formats depending on the vendor. Normalization is the process of extracting the relevant fields (e.g., Source IP, Username, Timestamp) from the raw text and mapping them to a standardized structure. This allows analysts to run a single query across Cisco firewalls, Windows servers, and Linux machines simultaneously.
- **3. Storage & Indexing:** Once normalized, logs are stored in a database (like Elasticsearch) and indexed. Indexing is crucial—it functions like the glossary of a book, allowing the SIEM to search through terabytes of data in milliseconds rather than hours.
- **4. Retention:** Organizations cannot keep data forever due to storage costs, but they must keep it long enough for compliance (e.g., GDPR, HIPAA, PCI-DSS) and historical threat hunting. SOCs use tiered storage:
 - *Hot Storage:* Recent logs (e.g., 30 days) kept on fast, expensive drives for immediate querying.
 - *Cold Storage:* Older logs (e.g., 1–7 years) compressed and moved to cheaper, slower storage for compliance archiving.
- **5. Analysis:** The final stage where the normalized, indexed data is used to populate dashboards, trigger automated SIEM alerts, and allow Tier 2/3 analysts to hunt for advanced threats.

B. Common Log Types

A SOC analyst must be intimately familiar with the anatomy of different log sources to understand what an attacker might be doing.

- **Windows Event Logs (EVTX):** The backbone of endpoint monitoring in corporate environments. They track system, application, and security events. Analysts look for specific Event IDs.
 - *Examples:* Event ID **4624** (Successful Logon), **4625** (Failed Logon—useful for detecting brute-force attacks), or **4688** (A new process has been created—useful for detecting malware execution).



23/Feb/2026

- **Syslog:** The standard logging protocol for Linux/Unix systems and network hardware (routers, switches, firewalls). Syslogs are categorized by "Facility" (what generated the log, like the kernel or a mail server) and "Severity" (ranging from 0/Emergency to 7/Debug).
- **HTTP Server Logs (Web Logs):** Generated by web servers like Apache, Nginx, or IIS. They record every request made to a website.
 - *Key Fields:* Source IP, HTTP Method (GET, POST), URI (the requested web page), User-Agent (the browser type), and Status Code (e.g., 200 OK, 404 Not Found).
 - *Use Case:* SOC's monitor these logs to detect web attacks, such as SQL Injection (SQLi) attempts hidden in the URI, or Directory Traversal attacks.

C. Practical Execution and Tooling

To implement log management in a practical lab environment, security engineers rely on specific tools and languages.

- **Data Aggregators (Logstash / Fluentd):** These tools sit in the middle of the log lifecycle. They are essentially ETL (Extract, Transform, Load) pipelines for logs. They receive raw data (Input), parse and mutate it (Filter), and send it to the final database (Output).
- **Standardized Formats: * JSON (JavaScript Object Notation):** The modern standard for log parsing. It stores data in key-value pairs (e.g., "source_ip": "192.168.1.5"), making it incredibly easy for SIEMs to index and query.
 - **CEF (Common Event Format):** An open log management standard originally developed by ArcSight, which standardizes the syntax for logging security events so different enterprise security tools can easily integrate.
- **Querying Languages (e.g., KQL):** To analyze the data, analysts use specialized query languages. **KQL (Kusto Query Language)** is the SQL-like syntax used heavily in Microsoft Azure Sentinel and Microsoft Defender.
 - *Example Concept: A basic KQL query to find failed logins might look like:*
`SecurityEvent | where EventID == 4625 | summarize count() by TargetUserName.`



23/Feb/2026

4: Security Tools Overview

A modern Security Operations Center relies on a layered "defense-in-depth" architecture. Because no single tool can catch every threat, SOC's utilize a conceptual framework known as the **SOC Visibility Triad**, which consists of SIEM, EDR, and NDR (Network Detection and Response). Together, these tools eliminate blind spots across the network perimeter, cloud environments, and individual devices.

A. SIEM (Security Information and Event Management)

The SIEM is the central nervous system of the SOC. It ingests telemetry from all other tools, correlates the data, and provides a single pane of glass for analysts.

1. Architectural Components:

- **Forwarders/Agents:** Lightweight programs installed on endpoints and servers that collect local logs and forward them to the SIEM.
- **Indexers:** The database engines that receive the raw logs, parse them into searchable key-value pairs, and store them on disk.
- **Search Heads:** The front-end web interface where analysts run queries, build dashboards, and configure alert rules.

2. Advanced Capabilities:

- **UEBA (User and Entity Behavior Analytics):** Modern SIEMs incorporate machine learning to establish a "normal" baseline for every user and device (entity). If an accountant who normally logs in from New York at 9 AM suddenly accesses sensitive HR servers from an overseas IP at 3 AM, UEBA flags this anomaly even if no specific malware signature is detected.
- **Industry Leaders:** **Splunk** (highly customizable, uses SPL - Search Processing Language), **IBM QRadar**, and cloud-native solutions like **Microsoft Sentinel**.

B. EDR (Endpoint Detection and Response) & XDR

While legacy Antivirus (AV) relied on a database of known bad file hashes (signatures), EDR assumes malware can bypass AV and focuses on behavioral monitoring at the operating system level.

1. How EDR Works: EDR relies on software agents installed at the kernel level of an operating system. It monitors low-level system events through API hooking:

- **Process Execution:** Tracking which parent processes spawn which child processes. (e.g., Microsoft Word spawning cmd.exe or powershell.exe is highly suspicious).
- **Memory Injection:** Detecting if a malicious program is trying to hide its code inside the memory space of a legitimate program (like explorer.exe).
- **Registry & File Changes:** Monitoring for persistence mechanisms (malware ensuring it runs every time the computer reboots).



23/Feb/2026

2. The Evolution to XDR: XDR (Extended Detection and Response) is the evolution of EDR. It takes the deep endpoint visibility of EDR and integrates it natively with network, cloud, and identity data, effectively merging EDR and SIEM capabilities into a more streamlined platform.

- **Industry Leaders: CrowdStrike Falcon, SentinelOne,** and Microsoft Defender for Endpoint.

C. IDS / IPS (Intrusion Detection and Prevention) & NDR

These tools sit on the network layer, inspecting the actual packets of data (PCAPs) flowing across the wire.

1. Deployment Architecture:

- **IDS (Passive):** Deployed out-of-band, usually connected to a switch's SPAN port or a network TAP. It receives a *copy* of the traffic. It cannot block an attack; it can only alert the SIEM.
- **IPS (Active):** Deployed inline (in-band), often directly behind the firewall. All traffic must flow *through* it. If it detects malicious packets, it drops them instantly.

2. Detection Methodologies:

- **Signature-Based:** Compares packet payloads against a database of known exploits. It is fast and highly accurate for known threats but blind to "zero-day" (brand new) attacks. **Snort** is the industry-standard engine for this.
- **Anomaly-Based (NDR):** Network Detection and Response tools use AI to understand normal network traffic patterns. If a server suddenly starts exfiltrating gigabytes of encrypted data to an unknown external IP, NDR detects the anomaly and alerts the SOC, even without a known signature.

D. Vulnerability Scanners

While SIEM, EDR, and IDS are reactive tools (catching active threats), vulnerability scanners are proactive. They map the attack surface to find weaknesses before an adversary does.

1. Types of Scans:

- **Unauthenticated Scans:** The scanner acts like an external hacker, probing IP addresses and open ports to see what services are running and if any glaring vulnerabilities are visible from the outside.
- **Authenticated Scans:** The scanner is provided with admin credentials to log into the target machines. This allows it to check deep into the registry, verify exact software versions, and find hidden misconfigurations.



23/Feb/2026

2. The CVSS Framework: When a scanner like **Tenable Nessus** or **Qualys** finds a flaw (a CVE - Common Vulnerabilities and Exposures), it ranks it using the **CVSS (Common Vulnerability Scoring System)**.

- **Base Score:** Represents the inherent qualities of a vulnerability (e.g., Can it be exploited remotely? Does it require high privileges?).
- **Temporal & Environmental Scores:** Modifiers that adjust the score based on whether a patch exists, or how critical the specific vulnerable server is to the business.
- **SOC Workflow:** Analysts prioritize patching "Critical" (9.0-10.0) and "High" (7.0-8.9) vulnerabilities first.

5: Basic Security Concepts

While tools and specific attacks constantly evolve, the foundational principles of cybersecurity remain static. Understanding these core concepts is essential for a SOC analyst to accurately evaluate alerts, assess the severity of an incident, and recommend appropriate remediation steps.

A. The CIA Triad

The CIA triad is the definitive model used to guide policies for information security within an organization. Every security control implemented by a SOC is designed to protect at least one of these three pillars.

- **Confidentiality:** Ensuring that sensitive information is accessed only by authorized individuals. If a hacker steals customer credit card numbers, confidentiality has been breached.
 - *Protective Controls:* Encryption (data at rest and in transit), Multi-Factor Authentication (MFA), and strict access control lists (ACLs).
- **Integrity:** Guaranteeing that information is trustworthy, accurate, and has not been altered by unauthorized parties. If an attacker modifies a bank ledger to add zeroes to their account balance, integrity has been compromised.
 - *Protective Controls:* Hashing algorithms (e.g., SHA-256) to verify file integrity, digital signatures, and strict file permission controls.
- **Availability:** Ensuring that systems, applications, and data are accessible to authorized users when they need them. A Denial of Service (DoS) attack aims to destroy availability.
 - *Protective Controls:* Hardware redundancy, load balancing, off-site data backups, and DDoS mitigation services.



23/Feb/2026

B. Threat vs. Vulnerability vs. Risk

These three terms are often used interchangeably in casual conversation, but in a SOC, they have highly specific definitions and form the basis of risk management.

- **Threat:** Any potential danger that could exploit a flaw to negatively impact an asset. Threats can be intentional (a hacker deploying ransomware) or unintentional (a hurricane destroying a data center, or an employee accidentally deleting a database).
- **Vulnerability:** A weakness or flaw in an information system, system security procedures, or internal controls. Examples include unpatched software, default administrative passwords, or a lack of employee security training.
- **Risk:** The potential for loss, damage, or destruction of an asset. Risk only exists when a threat intersects with a vulnerability.
 - *The Equation: **Risk = Threat × Vulnerability.*** (e.g., A severe threat actor trying to attack a system with zero vulnerabilities equals low risk. A highly vulnerable system that is completely disconnected from the internet and physical access equals low risk).

C. Architectural Security Models

To protect the CIA triad and manage risk, organizations employ strategic security architectures.

- **Defense-in-Depth:** Also known as the "castle approach." This is the practice of layering multiple, independent security controls throughout an IT system. The premise is that if one layer fails, the next layer will catch the threat.
 - *The Layers:* Physical security (guards/locks) $\rightarrow$ Perimeter (firewalls) $\rightarrow$ Internal Network (IDS/IPS) $\rightarrow$ Endpoint (EDR/Antivirus) $\rightarrow$ Application (Secure coding) $\rightarrow$ Data (Encryption).
- **Zero Trust Architecture (ZTA):** A modern security model that discards the old idea of a "trusted internal network" and an "untrusted external network."
 - *The Principle:* "Never trust, always verify." ZTA assumes that the network is always hostile and that breaches are inevitable or have already occurred. It requires strict, continuous authentication and authorization for every user and device, regardless of whether they are sitting inside the corporate office or working remotely.

D. Practical Application & Case Studies

To internalize these concepts, theoretical knowledge must be applied to real-world scenarios.

- **Terminology Mastery:** Utilizing spaced-repetition flashcards (e.g., Anki) to memorize standard security terminology, ensuring clear and precise communication during high-stress incident response scenarios.
- **Case Study Analysis: The 2017 Equifax Breach:**
 - *The Vulnerability:* Equifax failed to patch a known vulnerability (CVE-2017-5638) in their Apache Struts web application framework.
 - *The Threat:* Attackers actively scanning the internet for this exact weakness.
 - *The Failure of Defense-in-Depth:* Once inside the web server, the attackers found a lack of internal network segmentation (a failure of Defense-in-Depth).



23/Feb/2026

They moved laterally and found plain-text credentials, allowing them to query databases unhindered.

- *The Impact:* A massive breach of *Confidentiality*, resulting in the theft of personal data (Social Security numbers, birth dates) of approximately 147 million people. Analyzing failures like this teaches SOC analysts how threat actors chain vulnerabilities together.

6: Security Operations Workflow

A Security Operations Center cannot function on ad-hoc reactions; it requires a highly structured, repeatable workflow. This operational pipeline ensures that every alert is handled consistently, efficiently, and thoroughly. A well-defined workflow is what separates a proactive, mature SOC from a chaotic, reactive one.

A. The Complete Incident Response Lifecycle

The SOC workflow maps directly to the standard Incident Response (IR) lifecycle. Every ticket generated in the SOC must flow through these specific gates.

1. Detection & Alert Generation:

- **The Trigger:** Automated security tools (SIEM, EDR, NDR) ingest telemetry and fire alerts when behavioral rules or signature matches are triggered.
- **Alert Enrichment:** Before a human even sees the alert, a mature SOC uses automation to "enrich" it. For example, if an alert contains an IP address, the system automatically queries an external threat intelligence feed (like VirusTotal or AlienVault OTX) and appends the IP's reputation score to the ticket.

2. Triage & Qualification (Tier 1):

- **The Filter:** Analysts must rapidly assess the alert against Service Level Agreements (SLAs)—often having less than 15 minutes to triage a High-severity alert.
- **Contextualization:** The analyst asks: *Is this normal for this user? Is this a critical business asset?*
- **The Verdict:** Determining if the alert is a **False Positive** (benign activity, such as an admin running a vulnerability scan) or a **True Positive** (a genuine threat requiring escalation).

3. Investigation & Threat Hunting (Tier 2/3):

- **Root Cause Analysis (RCA):** Incident Responders take over to determine the exact attack vector. They build a timeline of events by correlating logs across multiple systems (e.g., matching a firewall connection log to an endpoint process execution log).
- **Indicator of Compromise (IOC) Hunting:** Analysts extract artifacts left behind by the attacker. To understand the value of different IOCs, analysts use **The Pyramid of Pain**.
- *The Pyramid of Pain concept:* Not all IOCs are equal. Blocking a malicious file hash (bottom of the pyramid) is easy for the SOC, but trivial for the attacker to change.



23/Feb/2026

Blocking the attacker's Tactics, Techniques, and Procedures or TTPs (top of the pyramid) is extremely hard for the SOC to detect, but causes maximum pain to the attacker because they have to reinvent their entire attack methodology.

4. Containment, Eradication, & Recovery:

- **Short-Term Containment:** Stopping the immediate bleeding. Example: Using EDR to sever a compromised laptop's network connection, isolating it while keeping it powered on to preserve RAM for forensic analysis.
- **Long-Term Containment:** Applying temporary patches or blocking IP ranges at the firewall to prevent further exploitation while a permanent fix is developed.
- **Eradication:** Removing the root cause. This involves deleting malware, disabling compromised user accounts, and patching the initial vulnerability the attacker exploited.
- **Recovery:** Carefully restoring the affected systems to normal business operations and monitoring them closely for reinfection.

5. Post-Incident Activity (Lessons Learned):

- The most critical, yet often skipped, phase. The SOC team holds a debrief to ask: *What happened? Why didn't we catch it sooner? How can we tune our SIEM rules to detect this automatically next time?*

B. Practical Tooling: Security Incident Response Platforms (SIRP)

To manage this complex workflow, SOC's use specialized platforms rather than standard IT helpdesk software.

- **TheHive Project:** A popular, open-source SIRP designed for SOC's. It allows multiple analysts to collaborate simultaneously on a single "Case."
- **SOAR Integration:** TheHive integrates seamlessly with SOAR (Security Orchestration, Automation, and Response) engines like **Cortex**. Cortex can automatically execute Python scripts (Analyzers) to check observables (IPs, domains) against dozens of threat intel feeds instantly, saving the analyst hours of manual copy-pasting.

C. Practical Task: Building a Phishing Incident Flowchart

Standardizing the response to a reported phishing email is a foundational SOC exercise. When you build your flowchart for this internship task, structure your playbook using the following logical decision trees:

Step-by-Step Phishing Playbook:

1. **Ingestion:** User forwards a suspicious email to phishing@company.com. A ticket is auto-generated in TheHive.
2. **Extraction (Automated):** The platform extracts the Sender IP, Email Headers, Attachment Hashes, and embedded URLs.
3. **Enrichment (Automated):** Hashes and URLs are scanned via Cortex/VirusTotal.
4. **Analysis (Human):** Analyst reviews the enriched data and the email body for social engineering red flags.



23/Feb/2026

5. **Decision Node:** Is the email malicious?
 - *Path A (No):* Mark as False Positive. Send an educational, reassuring email to the reporting user. Close ticket.
 - *Path B (Yes):* Mark as True Positive. Initiate Containment phase.
6. **Scoping:** Analyst queries the email gateway: *Did anyone else in the company receive this exact email?*
7. **Containment Actions:**
 - Purge the malicious email from all corporate inboxes.
 - Block the sender's domain/IP at the email gateway.
 - Add the malicious URLs to the web proxy blocklist.
8. **Impact Assessment:** Query the SIEM/Proxy logs: *Did any user actually click the link and submit their credentials?*
 - *If Yes:* Immediately force a password reset for that user and isolate their workstation for EDR scanning.
9. **Documentation:** Record all extracted IOCs, update the ticket with the timeline, and close the incident.

7: Incident Response Basics

Incident Response is the structured methodology an organization uses to handle a major cybersecurity event. The goal of IR is to handle the situation in a way that limits damage, reduces recovery time, and controls costs—both financial and reputational.

A. The Incident Response Lifecycle (NIST SP 800-61)

The industry standard for IR is defined by the National Institute of Standards and Technology (NIST) in their Special Publication 800-61. This framework breaks down the chaotic nature of a cyberattack into a predictable, manageable lifecycle consisting of six distinct steps (often grouped into four broader phases).

- **1. Preparation:**
 - *The Concept:* The most critical phase. An organization cannot effectively respond to a crisis if they are making up the rules on the fly.
 - *Key Activities:* Establishing an Incident Response Team (CSIRT), drafting IR playbooks for specific threats (e.g., ransomware, insider threat), ensuring logging tools (SIEM/EDR) are properly configured, and establishing secure out-of-band communication channels (since internal email might be compromised).
- **2. Identification (Detection & Analysis):**
 - *The Concept:* Discovering the incident and determining its exact scope.
 - *Key Activities:* Gathering events from logs, analyzing network traffic, and confirming if the event is a "True Positive" breach. The IR team answers the critical questions: *Who is the attacker? What systems are compromised? Is data being exfiltrated right now?*



23/Feb/2026

- **3. Containment:**
 - *The Concept:* Stopping the bleeding and preventing the threat from spreading laterally across the network.
 - *Short-Term Containment:* Immediate, reactive steps, such as disconnecting an infected server from the network switch or turning off an affected router.
 - *Long-Term Containment:* Implementing temporary fixes to allow systems to remain online securely while the root cause is addressed (e.g., applying a temporary firewall block rule or routing traffic through a "sinkhole").
- **4. Eradication:**
 - *The Concept:* Completely removing the adversary and their artifacts from the environment.
 - *Key Activities:* Deleting malicious files, disabling compromised user accounts, removing unauthorized registry keys, and patching the initial vulnerability the attacker used to get in.
- **5. Recovery:**
 - *The Concept:* Safely bringing affected systems back into production environments.
 - *Key Activities:* Reimaging infected hard drives from clean base images, restoring data from offline backups, changing all administrative passwords, and closely monitoring the systems for a specified duration to ensure the attacker does not return.
- **6. Lessons Learned (Post-Incident Activity):**
 - *The Concept:* A formal debriefing held within two weeks of the incident. It closes the loop, feeding directly back into the "Preparation" phase.
 - *Key Activities:* The team documents what happened, evaluates how well the IR plan worked, and identifies gaps in their defense. This leads to new SIEM detection rules, updated playbooks, or requests for better security tools.



23/Feb/2026

B. Practical Application: How to Train for IR

Because true cybersecurity incidents are high-stress and (hopefully) rare, SOC teams must constantly train to keep their skills sharp.

- **Studying the Framework:** Reading the actual NIST SP 800-61 Rev. 2 document is mandatory for a SOC intern. It provides the legal, procedural, and technical definitions that the entire cybersecurity industry relies upon.
- **Tabletop Exercises (TTX):**
 - *What it is:* A tabletop exercise is a non-technical, role-playing discussion. It brings together key stakeholders—not just the IT team, but also HR, Legal, Public Relations, and Executive Leadership—to walk through a simulated disaster scenario.
 - *Simulating a Ransomware Attack:* In a ransomware TTX, a facilitator presents a scenario: *"It is 8:00 AM on a Monday. All hospital patient databases are encrypted, and there is a ransom note demanding \$5 million in Bitcoin. Go." **
The Value: The team must discuss their response using their documented IR plan. It reveals critical procedural flaws without any real-world risk. For example, during a TTX, an organization might realize that their IR plan requires printing out network diagrams, but the printers are all connected to the encrypted network.



23/Feb/2026

Practical Task

1: Log Analysis Practice

Objective: Generate simulated attack traffic, find it using Windows Event Viewer, and export the evidence.

Step 1: Generate the "Attack" Traffic

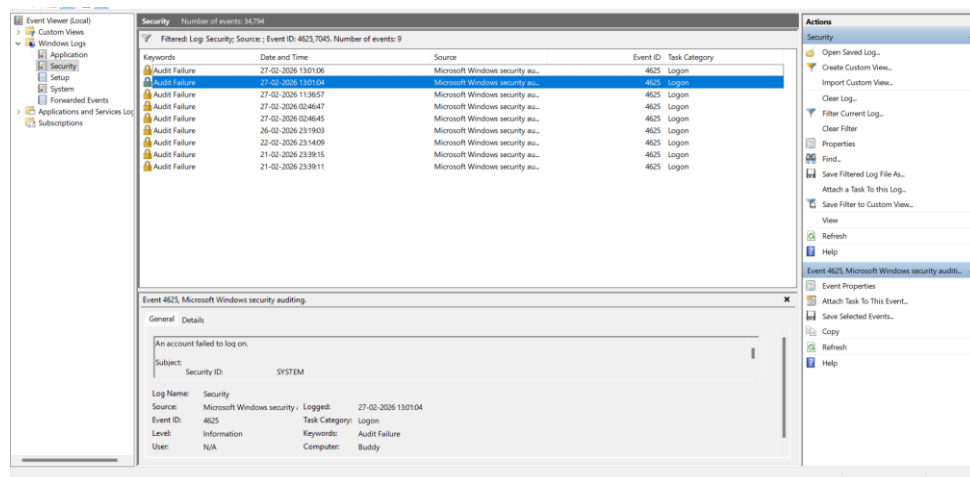
We need to create the telemetry first.

1. Lock your Windows VM (Windows Key + L).
2. Attempt to log in with an incorrect password 5 to 10 times to simulate a brute-force attack.
3. Log in with your correct password.

Step 2: Filter the Logs (GUI Method)

Now, let's play the role of the SOC analyst hunting for those failed attempts.

1. Click the Start menu, type **Event Viewer**, and hit Enter.
2. In the left pane, expand **Windows Logs** and click on **Security**. (It might take a few seconds to load).
3. In the right-hand **Actions** pane, click **Filter Current Log...**
4. In the <All Event IDs> field, type 4625 (Failed Logon) and 7045 (New Service Creation - a common post-exploitation step for persistence).
5. Click **OK**. Your center pane will now only show your simulated brute-force attempts.
6. **To Export:** Click **Save Filtered Log File As...** in the right pane, change the "Save as type" to **CSV (Comma Separated Values)**, and save it as **BruteForce_Evidence.csv**.





23/Feb/2026

Browser History Analysis:

Objective: Extract and parse the hidden SQLite database where Google Chrome stores user history to find a specific visited URL.

Step 1: Create the Artifact

1. Open Google Chrome in your Windows.
2. Visit a specific test site.
3. Close Chrome. (Important: Chrome locks its database while open, which can prevent forensics tools from reading it).

Step 2: Locate the Chrome History Database

Chrome doesn't store history in a readable text file; it uses a hidden SQLite database.

1. Open File Explorer.
2. Navigate to: C:\Users\aditya\AppData\Local\Google\Chrome\User Data\Default\.
3. Look for a file simply named **History** (it won't have a file extension, but it is an SQLite file).

Step 3: Parse with Zimmerman's SQLECmd

1. Download **SQLECmd** from Eric Zimmerman's tool repository and extract it to a folder .
2. Open a Command Prompt as Administrator and navigate to that folder.
3. Run the tool, pointing it at the Chrome History file and telling it where to save the output.
4. **The Analysis:** Go to your Desktop and open the newly generated CSV file. Use Ctrl+F to search for test.com. You will see the exact timestamp, visit count, and URL, proving the "user" visited that site.

```
Command Prompt
C:\Users\Aditya\Downloads\SQLECmd>SQLECmd.exe -f "C:\Users\Aditya\AppData\Local\Google\Chrome\User Data\Default\History" --csv "C:\Users\Aditya\Desktop"
SQLECmd version 1.1.0.0

Author: Eric Zimmerman (saericzimmerman@gmail.com)
https://github.com/EricZimmerman/SQLECmd
Command line: -f C:\Users\Aditya\AppData\Local\Google\Chrome\User Data\Default\History --csv C:\Users\Aditya\Desktop

Maps loaded: 92
Processing C:\Users\Aditya\AppData\Local\Google\Chrome\User Data\Default\History...
Map queries found: 1. Processing queries...
Dumping Chromium Browser Downloads to C:\Users\Aditya\Desktop\20260227083101114915_ChromiumBrowser_Downloads_0b575bcf-ade3-44e5-8162-eb52a96c2b06.csv
Map queries found: 1. Processing queries...
Dumping Chromium Browser History to C:\Users\Aditya\Desktop\20260227083101460321_ChromiumBrowser_HistoryVisits_1f37cc07-2b10-4c80-b845-84708e4f7429.csv
Map queries found: 1. Processing queries...
Dumping Chromium Browser Keyword Searches to C:\Users\Aditya\Desktop\20260227083101779791_ChromiumBrowser_KeywordSearches_d968ece4-d24a-4baf-8f07-78da07727712.csv
For map w/ description Edge Browser History Screenshots, got value 0 from IdentityQuery, but expected 1. Queries will not be processed!

Processed 1 file in 1.0105 seconds
```



23/Feb/2026

```
Description: Chromium Browser Media History Playback Session
Author: Andrew Rathbun
Email: andrew.d.rathbun@gmail.com
Id: 22fd15b3-3028-4b95-b706-829eca7d1bc4
Version: 1.0
CSVPrefix: ChromiumBrowser
FileName: Media History
IdentifyQuery: SELECT count(*) FROM sqlite_master WHERE type='table' AND (name='origin' OR name='playback' OR name='playbackSession');
IdentifyValue: 3
Queries:
-
  Name: Chromium Browser Media History Playback Session
  Query: |
    SELECT
      playbackSession.id AS ID,
      datetime( playbackSession.last_updated_time_s + ( strftime( '%s', '1601-01-01' ) ), 'unixepoch', 'localtime' ) AS LastUpdated,
      playbackSession.url AS URL,
      CAST ( playbackSession.duration_ms AS FLOAT ) / 1000 AS DurationInSeconds,
      CAST ( playbackSession.position_ms AS FLOAT ) / 1000 AS PositionInSeconds,
      playbackSession.title AS Title,
      playbackSession.artist AS Artist,
      playbackSession.album AS Album,
      playbackSession.source_title AS SourceTitle,
      playbackSession.origin_id AS OriginID
    FROM
      playbackSession
    ORDER BY
      playbackSession.id
  BaseFileName: MediaHistoryPlaybackSession
```

2: Documenting Security Events

Objective: To establish a standardized procedure for logging and tracking security anomalies, ensuring all critical data points are captured for shift handovers, incident response, and historical analysis.

Practical Scenario Execution (Mock Event)

Scenario: The SIEM triggered a threshold alert for excessive authentication failures originating from an internal network segment.

Date / Time (IST)	Source IP	Event ID	Description	Action Taken	Status
2026-02-27 14:15:00	192.168.1.10	4625 (Failed Logon)	Brute-Force Attempt: Detected 15 failed login attempts within a 5-minute window targeting the local Administrator account.	Triage: Validated Source IP belongs to the internal DHCP scope. Containment: Temporarily blocked IP 192.168.1.10 at the internal firewall. Escalation: Ticket assigned to Tier 2 for endpoint malware scanning via EDR.	Escalated (Tier 2)

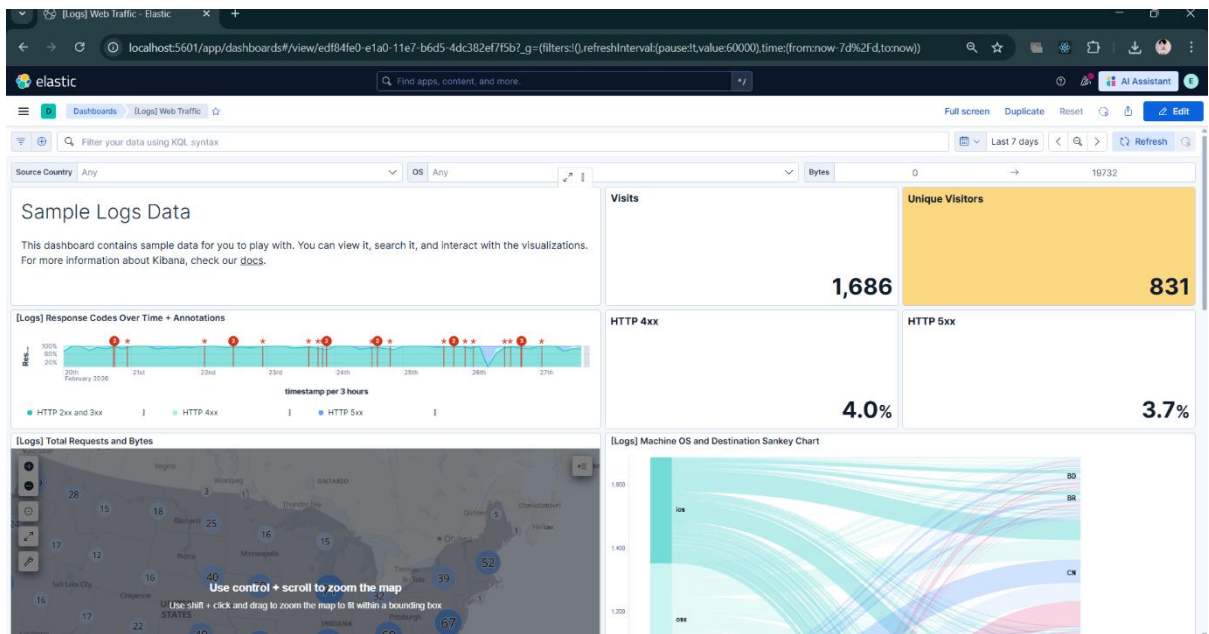


23/Feb/2026

3:Set Up Monitoring Dashboards

Step 1: Access Kibana & Load Sample Data

1. Open a web browser on your VM and go to **http://localhost:5601** (this is the default Kibana port). Log in if prompted.
2. On the welcome screen, look for a button that says **Try sample data** or **Add integrations** (if you are on the home page, click the Elastic logo in the top left, then find "Sample Data").
3. Choose **Sample web logs** and click **Add data**.





23/Feb/2026

Step 2: Build Visualization 1 (Top 10 Source IPs)

Now let's build the first requirement on your list: identifying the top 10 IPs generating the most traffic.

1. Click the **three horizontal lines (Hamburger menu)** in the top left.
2. Under the **Analytics** section, click **Dashboard**.
3. Click the blue **Create dashboard** button, then click **Create visualization**. This opens *Kibana Lens*, the drag-and-drop editor.
4. On the left side, you will see a list of fields. Search for **clientip**.
5. Drag and drop clientip straight into the middle of the screen. Kibana will automatically create a bar chart!
6. **Make it a Top 10 list:** On the right-hand panel, look under the *Horizontal axis* or *Rows* section. Click on clientip, and ensure the **Number of values** is set to 10.
7. In the top right corner, click **Save and return**. You now have your first widget on the dashboard.



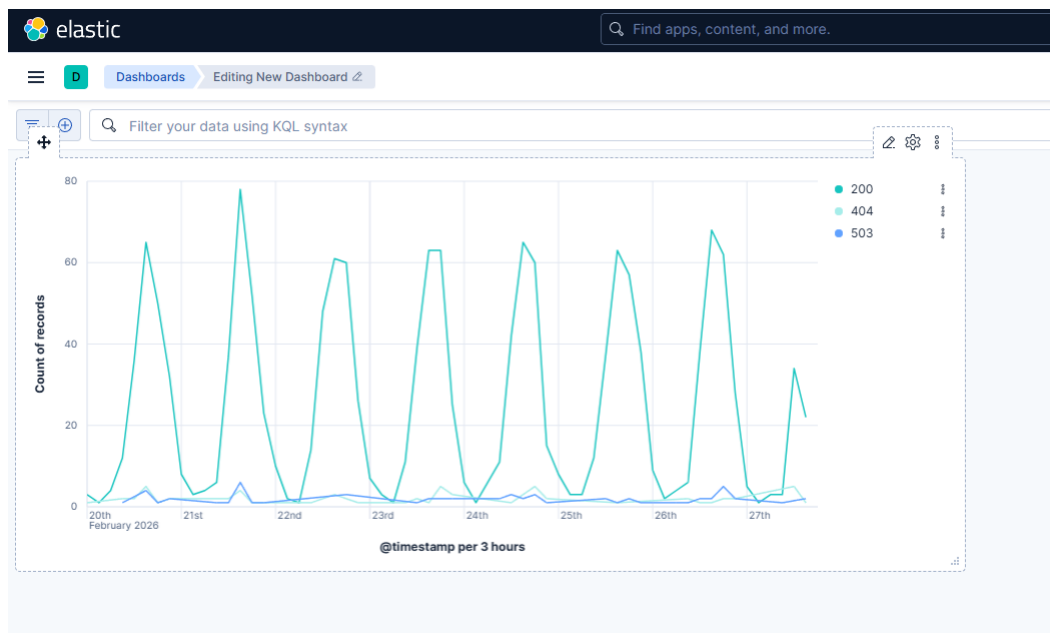


23/Feb/2026

Step 3: Build Visualization 2 (Event Frequency Over Time)

Your second requirement is checking the frequency of critical events. Since we are using web logs, we will track HTTP response codes (like 404 or 503 errors) to simulate tracking Windows Event IDs.

1. Back on your dashboard, click **Create visualization** again.
2. In the top right corner, change the chart type from "Bar vertical stacked" to **Line** or **Area**.
3. **Set the Timeline (X-Axis):** Drag the **@timestamp** field into the middle of the screen.
4. **Set the Frequency (Y-Axis):** Drag the **Records** field into the middle. You now have a line showing total traffic over time.
5. **Split the Events:** To see the specific "Event IDs" (Response codes), search for the **response.keyword** field on the left. Drag it into the **Break down by** section on the right-hand panel. *(Your single line will split into multiple colored lines, showing exactly when specific events spiked!)*
6. Click **Save and return**.





23/Feb/2026

4:Configure Alert Rules and SIEM Detection Logic

Objective: To implement automated threat detection by configuring custom threshold-based alert rules within Elastic SIEM and Wazuh. Furthermore, to validate these rules through simulated attack scenarios and map the resulting alerts to the MITRE ATT&CK framework.

Elastic SIEM Rule Configuration (Threshold Alerting)

To proactively detect brute-force attacks, a custom threshold rule was built within the Elastic Security environment.

- **Rule Objective:** Identify repeated authentication failures indicating a potential password guessing attack.
- **Configuration Parameters:**
 - **Rule Name:** Detect 5+ failed logins in 5 minutes
 - **Target Index:** security-login-*
 - **Condition:** count > 5
 - **Timeframe:** 5 minutes
- **Execution:** Navigated to Elastic Security > Rules > Create new rule. Selected "Threshold" as the rule type, defined the query to look for failed authentication logs, and set the threshold conditions as outlined above.

< Rules

Create new rule

Rule preview

Define rule Edit

Index patterns

apm-*transaction* auditbeat-*
endgame-* filebeat-* logs-*
packetbeat-* traces-apm* winlogbeat-*
elastic-cloud-logs- *

Custom query

event.action: "failed-logon"

Rule type

Threshold

Timeline template

None

Threshold

Results aggregated by source.ip >= 5